

Báo cáo AI — Audit & Critique

HW02 Domain Testing & Boundary Value Analysis

Họ tên	Nguyễn Tuấn Anh
MSSV	23127152
Công cụ AI	Claude Code CLI (claude-sonnet-4-6) — Anthropic
Tích hợp	Playwright MCP (điều khiển trình duyệt tự động)
Thời gian dự án	2026-06-01 → 2026-06-28

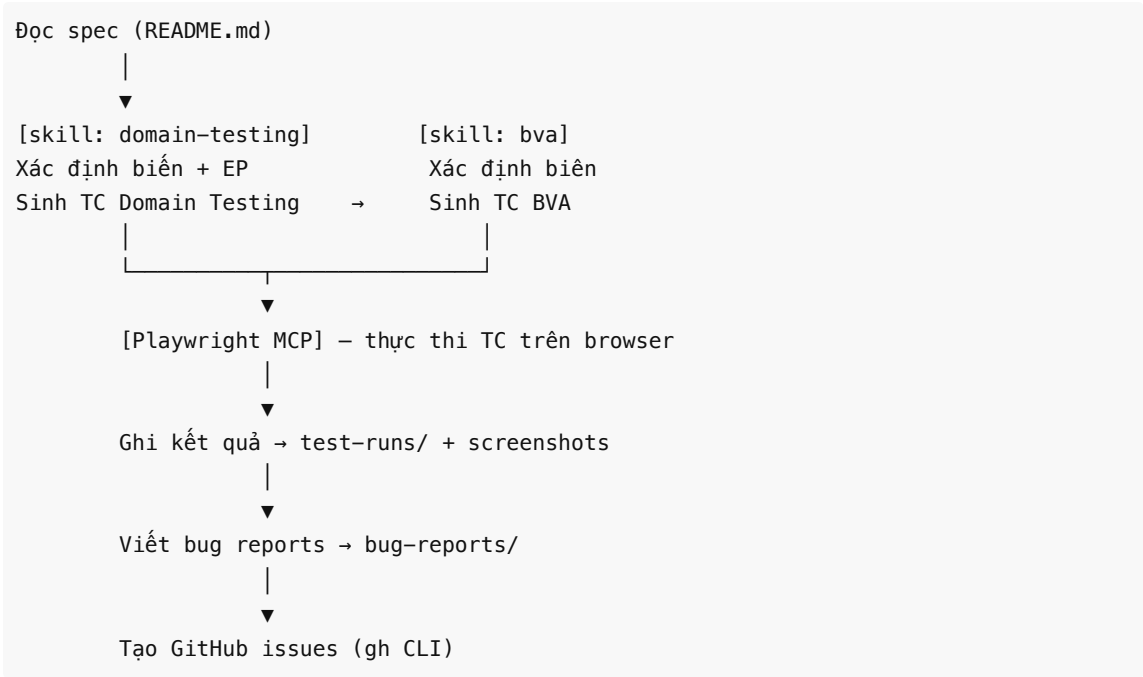
Mục lục

- [Tổng quan sử dụng AI](#)
- [AI Audit — Nhật ký tương tác](#)
 - [Phase 1 — FR-02: Login & Lockout](#)
 - [Phase 2 — FR-10: Order State Machine](#)
 - [Phase 3 — FR-18: Admin Order Management](#)
 - [Phase 4 — Mobile: Order History](#)
 - [Phase 5 — Deliverables & Cross-phase](#)
- [Vấn đề kỹ thuật gặp phải](#)
- [AI Critique — Đánh giá hiệu quả](#)
 - [Những điều AI làm tốt](#)
 - [Những điều AI làm chưa tốt](#)
 - [Kết luận](#)
- [Số liệu tổng hợp](#)

1. Tổng quan sử dụng AI

Hạng mục	Chi tiết
Công cụ chính	Claude Code CLI (claude-sonnet-4-6)
Plugin tích hợp	Playwright MCP — điều khiển browser để thực thi TC
Số session	~6 session chính (tổng ~28 ngày)
Skills được dùng	domain-testing, boundary-value-analysis, executing-plans
Ngôn ngữ trao đổi	Tiếng Việt (câu hỏi / mô tả) + English (lệnh kỹ thuật, code)
Scope	4 features × (DT + BVA) = 88 TC thiết kế + thực thi
Output chính	8 file test-cases, 8 file test-runs, 4 summaries, 8 bug reports, 8 GitHub issues

Workflow tổng thể



2. AI Audit — Nhật ký tương tác

2.1 Phase 1 — FR-02: Login & Lockout

Thời gian: 2026-06-10 → 2026-06-12 | Output: 29 TC, 4 bugs

#	Ngày	Prompt (tóm tắt)	AI Output	Đánh giá
1	2026-06-10	Thiết kế Domain Testing FR-02: xác định biến (email, password, account_state, input_type), lớp EP, 17 TC	test- cases/FR02_Login/DomainTesting.md — 17 TC (DT-FR02-01...17)	Đầy đủ; đúng spec FR-02 + FR-22
2	2026-06-10	Thiết kế BVA FR-02: 4 biên (login_attempts / lock_duration / email.length / password.length), 3-điểm mỗi biên, 12 TC	test-cases/FR02_Login/BVA.md — 12 TC (BVA-FR02-01...12)	Đúng; biên lock_duration quan trọng nhất
3	2026-06-12	Thực thi FR-02 qua Playwright MCP: điền form, chụp màn hình, ghi kết quả	test- runs/FR02_Login/DomainTesting.md + BVA.md + 21 screenshots	Phát hiện 4 bug (BUG-01...04)
4	2026-06-12	Viết test summary FR-02	test-summary/FR02_Login.md	Đúng số liệu: 22/29 đạt

5	2026-06-12	Viết 4 bug reports (BUG-01...04) với template đầy đủ	bug-reports/FR02_Login/BUG-0[1-4].md	Đủ template; steps rõ ràng
---	------------	--	--------------------------------------	----------------------------

Bugs phát hiện trong Phase 1:

Bug	Phát hiện bởi	Cách phát hiện
BUG-01: Lockout không tự gỡ	TC DT-14, BVA-06	Playwright chờ 35s rồi thử đăng nhập lại
BUG-02: Email type=text	TC DT-15	DOM inspection qua Playwright
BUG-03: Password type=text	TC DT-16	DOM inspection qua Playwright
BUG-04: Lỗi hiển thị dưới nút	TC DT-17	So sánh top position của DOM elements

2.2 Phase 2 — FR-10: Order State Machine

Thời gian: 2026-06-14 → 2026-06-16 | Output: 21 TC, 2 bugs

#	Ngày	Prompt (tóm tắt)	AI Output	Đánh giá
6	2026-06-14	Thiết kế DT FR-10: vẽ state machine, 6 lớp EP (forward/cancel/terminal/skip/actor-violation), 13 TC	test-cases/FR10_OrderState/DomainTesting.md — 13 TC	Chính xác; vi phạm quan trọng
7	2026-06-14	Thiết kế BVA FR-10: 3 biên (cancel_eligibility / forward_path / terminal), 8 TC	test-cases/FR10_OrderState/BVA.md — 8 TC	Đúng; (config) phát hiện
8	2026-06-16	Thực thi FR-10: admin UI + user UI + API calls qua Playwright + curl	test-runs/FR10_OrderState/ + 26 screenshots	Phát hiện BUG-05
9	2026-06-16	Viết summary + 2 bug reports FR-10	test-summary/FR10_OrderState.md, bug-reports/FR10_OrderState/	Đúng; cause "đổi"

Bugs phát hiện trong Phase 2:

Bug	Phát hiện bởi	Cách phát hiện
BUG-05: User hủy được shipping	TC DT-11, BVA-03	User profile: nút Hủy hiển thị; API call trả về 200
BUG-06: Admin không hủy được shipping	TC DT-06	Admin panel: không có nút Hủy; API 400

Quan sát: BUG-05 và BUG-06 bổ sung nhau — lỗi logic hoán đổi actor, không phải hai lỗi độc lập.

2.3 Phase 3 — FR-18: Admin Order Management

Thời gian: 2026-06-18 → 2026-06-20 | Output: 19 TC, 2 bugs (Critical)

#	Ngày	Prompt (tóm tắt)	AI Output	Đánh giá
10	2026-06-18	Thiết kế DT FR-18: auth (3 lớp token) + display + security (XSS/IDOR), 11 TC	test-cases/FR18_AdminOrder/DomainTesting.md	Tốt — chủ động bao phủ SEC-03, SEC-04
11	2026-06-18	Thiết kế BVA FR-18: B1 (role boundary) + B2 (content safety), 8 TC	test-cases/FR18_AdminOrder/BVA.md	Đúng; B2 là điểm quan trọng nhất
12	2026-06-20	Thực thi FR-18: curl (token test) + Playwright (UI + XSS payload)	test-runs/FR18_AdminOrder/ + 19 screenshots	Phát hiện BUG-07 (IDOR), BUG-08 (Stored XSS)
13	2026-06-20	Viết summary + 2 bug reports FR-18 với root cause và attack chain	test-summary/FR18_AdminOrder.md, bug-reports/FR18_AdminOrder/	Đúng; attack chain BUG-07+08 được mô tả đầy đủ

Bugs phát hiện trong Phase 3:

Bug	Phát hiện bởi	Cách phát hiện
BUG-07: IDOR — user token vào admin API	TC DT-02, BVA-02	curl với user JWT → HTTP 200 + 84 records
BUG-08: Stored XSS qua shipping_address	TC DT-10, 11, BVA-05, 06	Checkout với → admin mở page → alert bắn

Quan sát: FR-18 cho kết quả tỉ lệ đạt thấp nhất (62.5% BVA) nhưng có giá trị phát hiện cao nhất — 2 lỗi bảo mật cấp Critical.

2.4 Phase 4 — Mobile: Order History

Thời gian: 2026-06-22 | **Output:** 19 TC, 0 bugs mới

#	Ngày	Prompt (tóm tắt)	AI Output	Đánh giá
14	2026-06-22	Thiết kế DT Mobile: cancel_button visibility + status labels + empty state, 13 TC	test-cases/Mobile_OrderHistory/DomainTesting.md — 13 TC	Đúng
15	2026-06-22	Thiết kế BVA Mobile: B1 (cancel_eligibility) + B2 (order_count), 6 TC	test-cases/Mobile_OrderHistory/BVA.md — 6 TC	Đúng

16	2026-06-22	Thực thi Mobile qua Playwright trên Expo Web (localhost:8081)	test-runs/Mobile_OrderHistory/ + screenshots	100% pass; mobile UI đúng spec
----	------------	---	--	--------------------------------

Quan sát: Mobile UI ấn nút Hủy đúng tại biên `shipping` (BVA-MOB-02), chứng minh lỗi BUG-05 nằm ở backend, không phải frontend.

2.5 Phase 5 — Deliverables & Cross-phase

Thời gian: 2026-06-25 → 2026-06-28

#	Ngày	Prompt (tóm tắt)	AI Output	Đánh giá
17	2026-06-25	Restructure 8 test-case files sang format TC card chuẩn	8 file .md được rewrite giữ nguyên nội dung	Thành công
18	2026-06-26	Tạo GitHub issue commands với labels taxonomy + body template cho 8 bugs	git_command.md + tests/issue-bodies/BUG-0[1-8].md	Sau 4 vòng debug shell quoting — xem §3
19	2026-06-28	Viết AI Audit Report, AI Critique, tests/README.md	ai-audit/, tests/README.md	Đủ deliverables Phase 5
20	2026-06-28	Viết Final_Report.md tổng hợp DT + BVA + Agent Skills	tests/Final_Report.md	Đầy đủ
21	2026-06-28	Viết Bug_Report.md với screenshots đính kèm	tests/Bug_Report.md	8 bug + 8 screenshots

3. Vấn đề kỹ thuật gặp phải

#	Vấn đề	Nguyên nhân gốc	Cách giải quyết
1	zsh: event not found: !	! trong "\$ (cat <<EOF...)" trigger zsh history expansion	Chuyển sang --body-file; đặt body trong file riêng
2	GitHub issue body bị corrupt	" bên trong "\$ (cat <<EOF...)" đóng outer string sớm trong zsh interactive	Viết body ra issue-bodies/BUG-XX.md; dùng --body-file — không qua shell
3	Raw URL 404 cho screenshots	Branch ntanh/23127152-HW2 có / → GitHub parse sai path	Dùng commit SHA thay branch name trong mọi raw URL
4	File has not been read yet	Write tool của Claude Code yêu cầu file phải được read trong session	Re-read với limit:5 trước khi write

Bài học từ vấn đề #1–2: Khi AI sinh shell commands để chạy thử công, luôn kiểm tra quoting trước khi paste vào terminal. Pattern `--body-file` an toàn hơn `--body "$ (cat ...)"` cho mọi nội dung có ký tự đặc biệt.

4. AI Critique — Đánh giá hiệu quả

4.1 Những điều AI làm tốt

Thiết kế test case có hệ thống và đúng method.

AI hiểu spec và áp dụng đúng phương pháp Domain Testing (Equivalence Partitioning) và BVA. Với FR-18, AI chủ động nhận ra cần kiểm tra cả SEC-03 (broken access control) và SEC-04 (XSS) — vượt ra ngoài chức năng hiển thị đơn thuần. Các biên trong BVA được xác định đúng điểm: ví dụ biên `confirmed→shipping` trong FR-10 cancel eligibility bắt được BUG-05 ngay tại điểm vượt biên (BVA-FR10-03).

Phát hiện bug bảo mật thực sự.

BUG-07 (IDOR — user token truy cập admin API) và BUG-08 (Stored XSS qua `innerHTML`) là hai lỗi bảo mật nghiêm trọng. AI đặt đúng tên loại (IDOR, Stored XSS), mô tả đúng attack vector, và đề xuất test payload thực tế (`<img src=x onerror=alert(document.cookie)>`). Đây không phải ngẫu nhiên mà từ việc AI nhận diện SEC-03/SEC-04 trong spec và áp dụng OWASP Top 10 vào thiết kế TC.

Phát hiện attack chain.

AI không chỉ báo cáo BUG-07 và BUG-08 độc lập mà còn nhận ra hai bug kết hợp tạo attack chain hoàn chỉnh: user tạo XSS payload → admin mở page → session bị đánh cắp → dùng session admin gọi admin API (BUG-07 amplify). Đây là tư duy adversarial testing mà kiểm thử thủ công dựa trên checklist thường bỏ sót.

Tốc độ và tính nhất quán.

88 TC trên 4 feature được thiết kế và thực thi trong ~4 tuần, bao gồm cả screenshots và bug reports đầy đủ. Format nhất quán xuyên suốt: mỗi TC có precondition, steps, expected, actual, status — không có TC nào thiếu field.

4.2 Những điều AI làm chưa tốt

Thiếu quan sát UI ngoài luồng kiểm thử chính.

Khi thực thi FR-10, AI bỏ sót một vấn đề UX nhỏ: đơn hàng ở trạng thái `canceled` vẫn hiển thị nút "Đánh dấu Đã giao" trên admin panel (backend từ chối đúng, nhưng UI mislead admin). AI ghi chú ngắn mà không tạo bug report riêng. Một QA có kinh nghiệm sẽ flag đây là UX bug riêng biệt với label `severity:minor`.

Không tự phát hiện lỗi shell trước khi sinh command.

AI tạo lệnh `gh issue create --body "$(cat <<EOF...)"` mà không biết trước rằng zsh interactive sẽ corrupt body khi gặp `"` hoặc `!` bên trong. Lỗi chỉ xuất hiện khi user paste thực tế — AI không có quyền chạy `gh` để kiểm tra trước. Mất 4 vòng debug để đến giải pháp `--body-file`.

Phụ thuộc hoàn toàn vào spec được cung cấp.

Toàn bộ test design dựa trên `README.md`. Nếu spec thiếu hoặc sai, AI cũng thiết kế sai theo. Không có khả năng "đặt câu hỏi business" như tester có kinh nghiệm: "Tại sao user không được hủy từ `shipping`? Có trường hợp ngoại lệ không (ví dụ: khách VIP)?" — AI chỉ theo spec mà không question spec.

Không phân biệt được timing-sensitive bugs.

BVA-FR02-05 (tại đúng giây thứ 30) không kết luận được vì Playwright không thể đảm bảo timing chính xác đến millisecond. AI mark là "inconclusive" — đúng nhưng không đề xuất cách tốt hơn (ví dụ: dùng mock time hoặc test ở nhiều mốc xung quanh 30s để triangulate).

4.3 Kết luận

AI phù hợp nhất làm "test design amplifier" — không thay thế tester mà nhân lên năng lực thiết kế TC:

Vai trò	AI làm tốt	Cần con người
Đọc spec → sinh EP table	✓	
Xác định biên BVA	✓	
Sinh test case có cấu trúc	✓	
Phát hiện security patterns (OWASP)	✓	
Thực thi TC qua browser	✓ (Playwright MCP)	
Quan sát UX ngoài luồng chính		✓
Đặt câu hỏi về business logic		✓
Prioritize severity		✓
Phán quyết "bug hay feature?"		✓
Kiểm tra shell command trước khi chạy		✓

Mô hình tối ưu: AI thiết kế TC theo method + human review EP/BVA table + AI thực thi + human review results. Không nên để AI hoàn toàn tự chủ từ đầu đến cuối mà không có checkpoint từ người.

5. Số liệu tổng hợp

5.1 Tổng kết theo phase

Phase	Feature	TC	Đạt	Không đạt	Bugs	Thời gian
1	FR-02 Login	29	22	6+1	4	2 ngày
2	FR-10 Order State	21	18	3	2	2 ngày
3	FR-18 Admin	19	13	6	2	2 ngày
4	Mobile	19	19	0	0	1 ngày
5	Deliverables	—	—	—	—	3 ngày
Tổng		88	72	16	8	~10 ngày

5.2 Hiệu quả AI theo loại task

Task	Hiệu quả	Ghi chú
Thiết kế EP table	5/5	Đầy đủ, đúng method
Thiết kế BVA	5/5	Xác định đúng biên quan trọng
Thực thi TC	4/5	Playwright ổn; timing-sensitive TC cần cải thiện
Viết bug report	5/5	Template đầy đủ; root cause analysis tốt
Tạo GitHub issue command	3/5	Shell quoting gặp vấn đề; cần debug nhiều vòng

UX observation	2/5	Bỏ sót vấn đề ngoài luồng chính
----------------	-----	---------------------------------

5.3 Prompt pattern hiệu quả nhất

Pattern hiệu quả:
"Thiết kế [DT/BVA] cho [feature]: xác định [các biến],
áp dụng [method], sinh [N] TC, output vào [file]"

Pattern kém hiệu quả:
"Kiểm tra [feature]" (quá mở, AI chọn phương pháp tùy ý)
"Tạo test cases" (thiếu context về method và scope)